

ConectaEPT

Avaliação anônima e não destrutiva do portal conectaept.educacao.ba.gov.br

Moderado

RISCO OBSERVADO

Data: 03/09/2026

Relatório: CEPT-EXT-2026-09-03

Modo: caixa-preta, sem autenticação

Impacto operacional: baixo

01 Resumo executivo

Não foi confirmado acesso administrativo anônimo, segredo incorporado ao frontend ou comprometimento direto do servidor. A avaliação encontrou riscos relevantes de privacidade no navegador, documentação excessiva da superfície da API e pontos de endurecimento que devem ser corrigidos.

0

Críticos confirmados

0

Altos confirmados

1

Médios confirmados

2

Médios condicionais

3

Baixos / informativos



Conclusão: não há evidência de uma invasão simples pela camada anônima examinada. Ainda assim, não é possível declarar o sistema seguro antes de validar autorização por objeto, perfis autenticados, uploads e controles de sessão em ambiente de homologação.

02

Escopo e método

Incluído nesta avaliação

- HTTPS, certificado, protocolos TLS, DNS e DNSSEC.
- Cabeçalhos HTTP, cookies, CORS, CSP e comportamento de redirecionamento.
- HTML e bundles JavaScript carregados publicamente.
- Rotas de API descobertas no cliente e na especificação OpenAPI.
- Arquivos públicos, source maps e indicadores de credenciais expostas.
- Requisições pontuais GET, HEAD e OPTIONS de baixo impacto.

Não incluído / limitações

- Testes com contas reais ou comparação entre perfis de acesso.
- Criação, alteração, exclusão ou upload de dados em produção.
- Fuzzing amplo, força bruta, exploração destrutiva ou varredura de portas.
- Análise de código-fonte, dependências e infraestrutura como código.
- Testes completos de BOLA/IDOR, regras de negócio e isolamento de tenant.

03 Achados técnicos

F-01 Dados pessoais sensíveis persistidos no navegador

MÉDIA

CONFIRMADO

Evidência

O formulário público grava automaticamente o objeto completo na chave `seminarios-project-form-draft:v1:{editionId}:{uid|public}` do `localStorage`, sem timestamp ou expiração.

Impacto

O rascunho pode conter CPF, RG, matrícula, data de nascimento, nome da mãe, etnia, telefone, necessidades especiais e restrições alimentares. Em perfil de navegador compartilhado, outro usuário pode recuperar esses dados.

Recomendação

Não persistir campos sensíveis no cliente. Preferir rascunho server-side vinculado a sessão segura; como mitigação temporária, usar armazenamento de sessão, minimização, TTL curto e limpeza explícita.

F-02 Tokens de acesso público sem expiração no cliente

MÉDIA

IMPACTO CONDICIONAL

Evidência

As chaves `seminarios-public-project-tokens:v1` e `seminarios-public-upload-owner:v1` permanecem no `localStorage`. O cliente conserva até 150 tokens e não implementa TTL ou rotina geral de remoção.

Impacto

Caso os tokens permaneçam válidos no servidor, quem obtiver acesso ao mesmo perfil do navegador, a uma extensão maliciosa ou a um XSS no mesmo domínio pode reutilizá-los. O escopo e a validade server-side não foram testados.

Recomendação

Substituir por sessão anônima server-side com cookie `HttpOnly; Secure; SameSite`, expiração curta, escopo mínimo, rotação e revogação. Tornar qualquer opção "lembrar neste dispositivo" explícita.

F-03 Swagger/OpenAPI expõe amplamente a superfície interna

MÉDIA

CONDICIONAL

Evidência

/api/docs e /api/docs/json estão públicos: 192 caminhos, 226 operações, 122 administrativas e 21 operações de exclusão.

Impacto

A documentação reduz o custo de reconhecimento e revela rotas de usuários, auditoria, diagnóstico, importação, exportação e upload. A especificação não aplica requisitos `security` às operações, embora o runtime testado tenha bloqueado acessos anônimos.

Recomendação

Proteger a documentação completa com SSO, VPN ou allowlist. Se houver consumo externo legítimo, publicar uma especificação separada apenas com as rotas públicas e documentar corretamente autenticação e CSRF.

F-04 HSTS e atributos de cookie inconsistentes

BAIXA

CONFIRMADO

Evidência

A API envia `Strict-Transport-Security`, mas a página principal não. O domínio não constava como preloaded. O cookie `cookiesession1`, aparentemente da borda/WAF, foi emitido por um ano sem `Secure` nem `SameSite` explícito.

Impacto

O primeiro acesso via HTTP permanece dependente do redirecionamento 301. Um cookie sem `Secure` pode ser enviado antes desse redirecionamento. A criticidade final depende da função real do cookie de borda.

Recomendação

Aplicar HSTS uniformemente no proxy/WAF e revisar a viabilidade de preload. Marcar o cookie como `Secure; SameSite=Lax` ou `Strict` e reduzir sua duração.

F-05 DTO público contém identificadores internos desnecessários

BAIXA

CONFIRMADO

Evidência

`/api/public/seminarios/editions` retorna IDs internos, parâmetros de workflow e `consolidatedById`.

Impacto

Não foram encontrados nome ou e-mail nessa resposta. Mesmo assim, identificadores válidos facilitam correlação, reconhecimento e tentativas de abuso de outras rotas que aceitam IDs.

Recomendação

Criar um DTO público por allowlist, retornando somente campos necessários à interface. Remover IDs de operadores, auditoria e estados internos do fluxo.

F-06 Metadados e resíduos de desenvolvimento

INFORMATIVA

CONFIRMADO

Evidência

Respostas revelam `X-Powered-By: Next.js` e versão do nginx. O HTML contém assinatura nominal de desenvolvedores; bundles mantêm fallback morto para `localhost:3333`; `security.txt` não foi publicado.

Impacto

Não há segredo nesses valores, mas eles facilitam fingerprinting e engenharia social, além de indicar que artefatos de desenvolvimento chegaram à produção.

Recomendação

Desabilitar banners de versão, remover assinaturas/TODOs e fallbacks de desenvolvimento do build. Publicar `/.well-known/security.txt` com canal de divulgação responsável.

04 Validação prioritária

POTENCIAL ALTO SE CONFIRMADO

Autorização por objeto em projetos públicos

A especificação anuncia `GET` e `PATCH /api/public/seminarios/projects/{id}` sem segurança documentada. Uma consulta com identificador sintético inexistente retornou `404`; nenhum projeto real foi usado, portanto não foi possível provar se um token é exigido para registros válidos.

Ação: testar em homologação com dois projetos semeados e tokens distintos. Se um ID válido puder ser lido ou alterado sem o token correspondente, classificar como BOLA/IDOR de alta severidade e corrigir antes de nova publicação.

05 Controles positivos observados



TLS 1.0/1.1 recusados; TLS 1.2/1.3, certificado e DNSSEC adequados.



CORS rejeitou origens externas e origem nula; origem oficial foi allowlisted.



Rotas privadas testadas responderam 401; rotas administrativas responderam 403.



O fluxo cliente aplica token CSRF em mutações privadas e renova a sessão.



CSP ativa com nonce variável; scripts examinados estavam associados ao nonce.



Nenhuma credencial, chave privada, JWT, URL de banco ou source map foi exposto.



Login e recuperação de senha usaram mensagens genéricas contra enumeração.



Resultados ainda não publicados permaneceram bloqueados para acesso anônimo.

06 Plano de correção recomendado

0-7 DIAS • URGENTE

Conter o risco de dados

1. Validar BOLA/IDOR com projeto controlado em homologação.
2. Parar de salvar CPF, RG e dados sensíveis em armazenamento persistente.
3. Definir expiração e revogação para tokens públicos.

8-30 DIAS • CURTO PRAZO

Reduzir a superfície

1. Restringir o Swagger completo e publicar documentação mínima.
2. Aplicar DTOs públicos por allowlist.
3. Uniformizar HSTS e atributos de cookies no proxy/WAF.

31-60 DIAS • GARANTIA

Comprovar os controles

1. Executar matriz de autorização com perfis diferentes.
2. Revisar uploads, anexos, rate limits, logs e alertas.
3. Realizar SAST, SCA e pentest autenticado após as correções.

07 Matriz resumida de evidências

TESTE	RESULTADO	LEITURA DE RISCO
<code>/api/auth/me</code> , notificações e arquivos	401	Controle de sessão presente na camada anônima.
Rotas administrativas e diagnósticos amostrados	403	Bloqueio de borda/backend observado.
CORS com origem externa e <code>null</code>	403	Não houve reflexão arbitrária de origem.
Resultados de edição não publicados	403	Flag de publicação foi respeitada.
<code>/api/docs</code> e <code>/api/docs/json</code>	200	Documentação completa disponível anonimamente.
HTTP para HTTPS	301	Redirecionamento presente; HSTS ainda precisa ser uniforme.

TESTE	RESULTADO	LEITURA DE RISCO
Arquivos sensíveis e source maps testados	404 / bloqueado	Nenhuma configuração ou fonte foi obtida.
Projeto público com ID sintético	404	Inconclusivo para um ID válido; requer homologação.

08 Critérios para encerramento

Este documento representa uma primeira fase externa, não um atestado de inviolabilidade. A avaliação deve ser reaberta após as correções e concluída com:

- código-fonte do frontend e backend, lockfiles e configuração do proxy/WAF;
- ambiente de homologação com dados fictícios;
- duas contas de perfis distintos e uma conta administrativa controlada;
- projetos e anexos semeados para testes de autorização por objeto;
- reteste independente dos achados F-01 a F-05.